

ESTUDIO DE CASO 1

Exposición de credenciales en el punto de entrada: Estudio de caso de phishing controlado en localhost

Por: Joseph Gonzalez



ZERODAY TECH LABS



Alcance	Simulación solo en localhost con credenciales de prueba autogeneradas y páginas controladas por el investigador; únicamente con fines educativos y analíticos
Entorno	Terminal Kali Linux, página de inicio de sesión de práctica alojada localmente, Firefox, SEToolkit, tráfico solo en localhost
Evidencia principal	Captura de lanzamiento de SET, captura de selección de ataque, captura del inicio de sesión de origen, captura del clon en localhost, captura de terminal redactada con barras negras

Solo con fines educativos y analíticos. Los detalles de direcciones locales y los valores enviados que aparecen en las figuras se han redactado con barras negras opacas.

Introducción

Los hogares son objetivos atractivos para el robo de credenciales porque los inicios de sesión cotidianos ocurren en teléfonos personales, laptops, tabletas y dispositivos familiares compartidos, a menudo bajo presión de tiempo y con reutilización repetida de contraseñas entre servicios. Los consejos tradicionales de concienciación, como "mirar cuidadosamente la página", son útiles, pero no siempre bastan cuando una interfaz clonada es visualmente convincente y el usuario ya espera iniciar sesión.

Este proyecto usa un enfoque basado en estudio de caso en lugar de una lista de verificación genérica de laboratorio. El objetivo es examinar en profundidad un único escenario controlado, documentar cómo se veía la interfaz, registrar qué ocurrió cuando se envió el formulario y explicar por qué el resultado importaría más allá del laboratorio.

Metodología

Se realizó una simulación de ciberseguridad controlada en un entorno de laboratorio virtual aislado con Kali Linux, una página HTML de inicio de sesión alojada localmente, un navegador web y SEToolkit como capa de instrumentación para observar el comportamiento del envío de formularios. El alcance se limitó a tráfico de localhost y datos de prueba autogenerados. No participaron víctimas reales, cuentas de terceros, hosts públicos ni sistemas de producción.

1. Descripción general

Una página de inicio de sesión clonada es una interfaz engañosa que imita una pantalla de acceso esperada y captura datos en el momento en que se envía el formulario. En este caso, la pregunta analítica era si una página de práctica alojada localmente, una vez clonada y presentada de nuevo mediante localhost, recopilaría credenciales de prueba autogeneradas durante una interacción controlada. Por ello, el caso se centra en la exposición en el punto de entrada, no en el almacenamiento de contraseñas del lado del servidor.

2. Configuración del ataque

El host de laboratorio se usó para preparar el flujo controlado de captura de credenciales. Como se muestra en la Figura 1, SET se inició en el entorno de laboratorio. La Figura 2 añade la vista de selección de ataque y muestra la ruta de recolección de credenciales usada para el escenario controlado. La Figura 3 muestra la interfaz de inicio de sesión de origen usada como página local de práctica. La importancia de esta etapa no fue la cuenta específica mostrada, sino que la interfaz se parecía lo suficiente a una experiencia normal de inicio de sesión como para permitir la interacción habitual del usuario durante la sesión controlada.

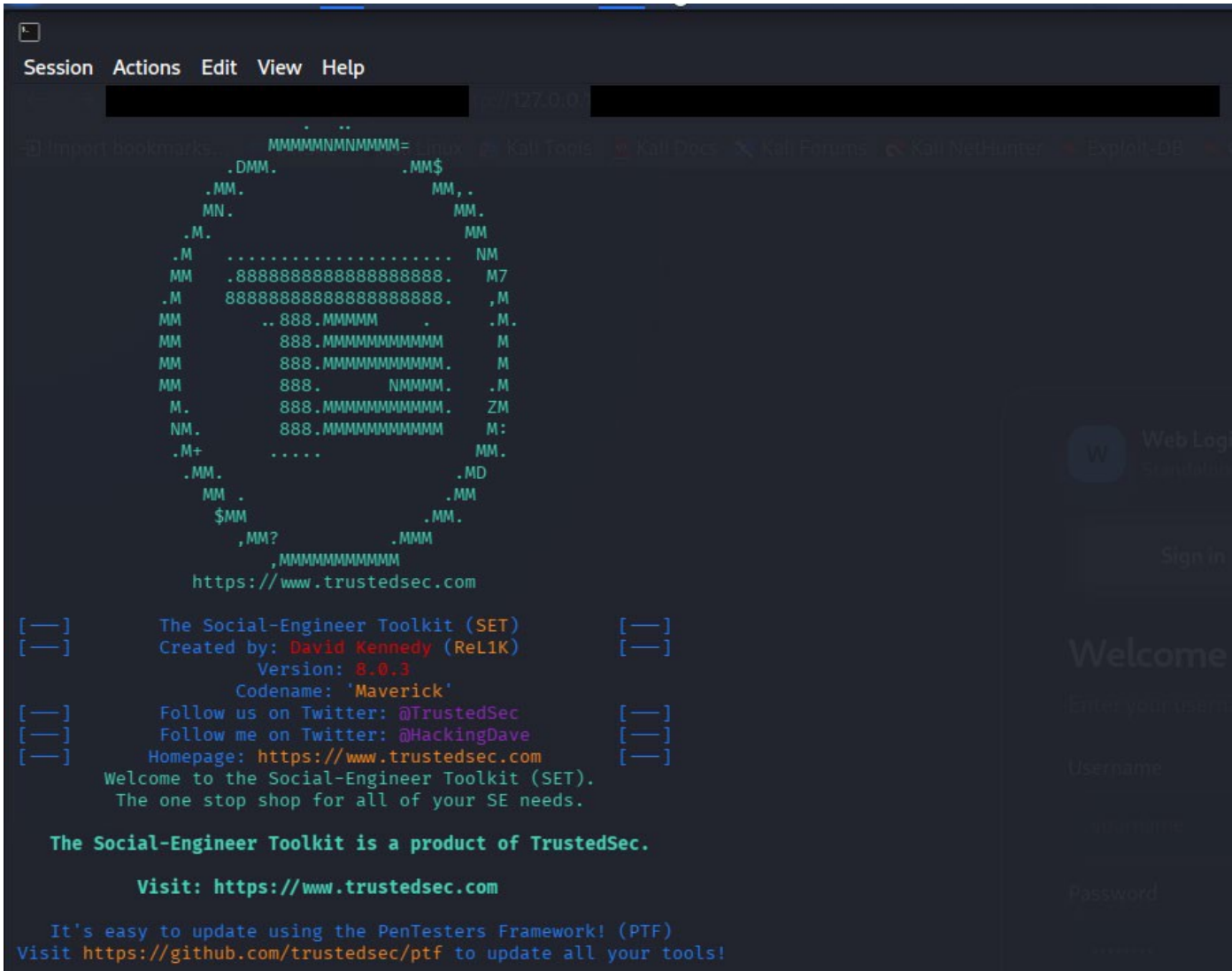


Figura 1. Entorno de lanzamiento de SET en el host de laboratorio, con los detalles de dirección local redactados mediante barras negras.

- 1) Java Applet Attack Method
- 2) Metasploit Browser Exploit Method
- 3) Credential Harvester Attack Method
- 4) Tabnabbing Attack Method
- 5) Web Jacking Attack Method
- 6) Multi-Attack Web Method
- 7) HTA Attack Method

99) Return to Main Menu

`set:webattack>3`

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

`set:webattack>2`

`[~]` Credential harvester will allow you to utilize the clone capabilities within SET
`[~]` to harvest credentials or parameters from a website as well as place them into a report

Figura 2. Vista de selección del ataque de recolección de credenciales de SET, que documenta la ruta de ataque controlada usada en la simulación de laboratorio.

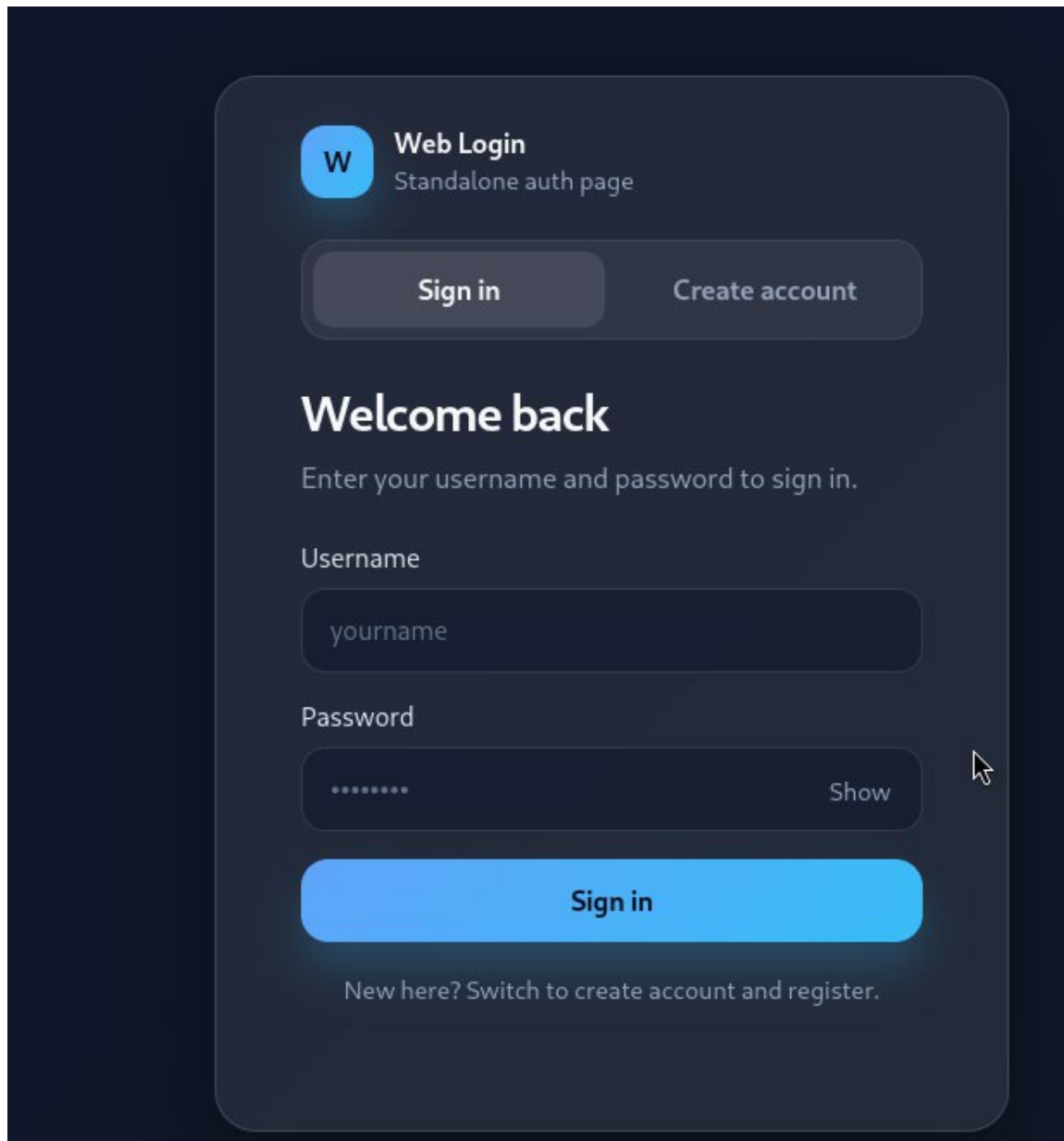


Figura 3. Interfaz de inicio de sesión de origen utilizada en la simulación controlada en localhost.

3. Ejecución

Como se muestra en la Figura 4, la interfaz clonada siguió accesible mediante localhost después de enviar las credenciales. En lugar de redirigir al usuario a una página de destino, la interfaz mostró un mensaje de error en línea que indicaba que no se podía alcanzar el servidor. Esto es importante desde el punto de vista analítico porque un usuario podría interpretar el resultado como un fallo rutinario de inicio de sesión o conectividad, y no como evidencia de que el envío inicial ya había sido procesado.

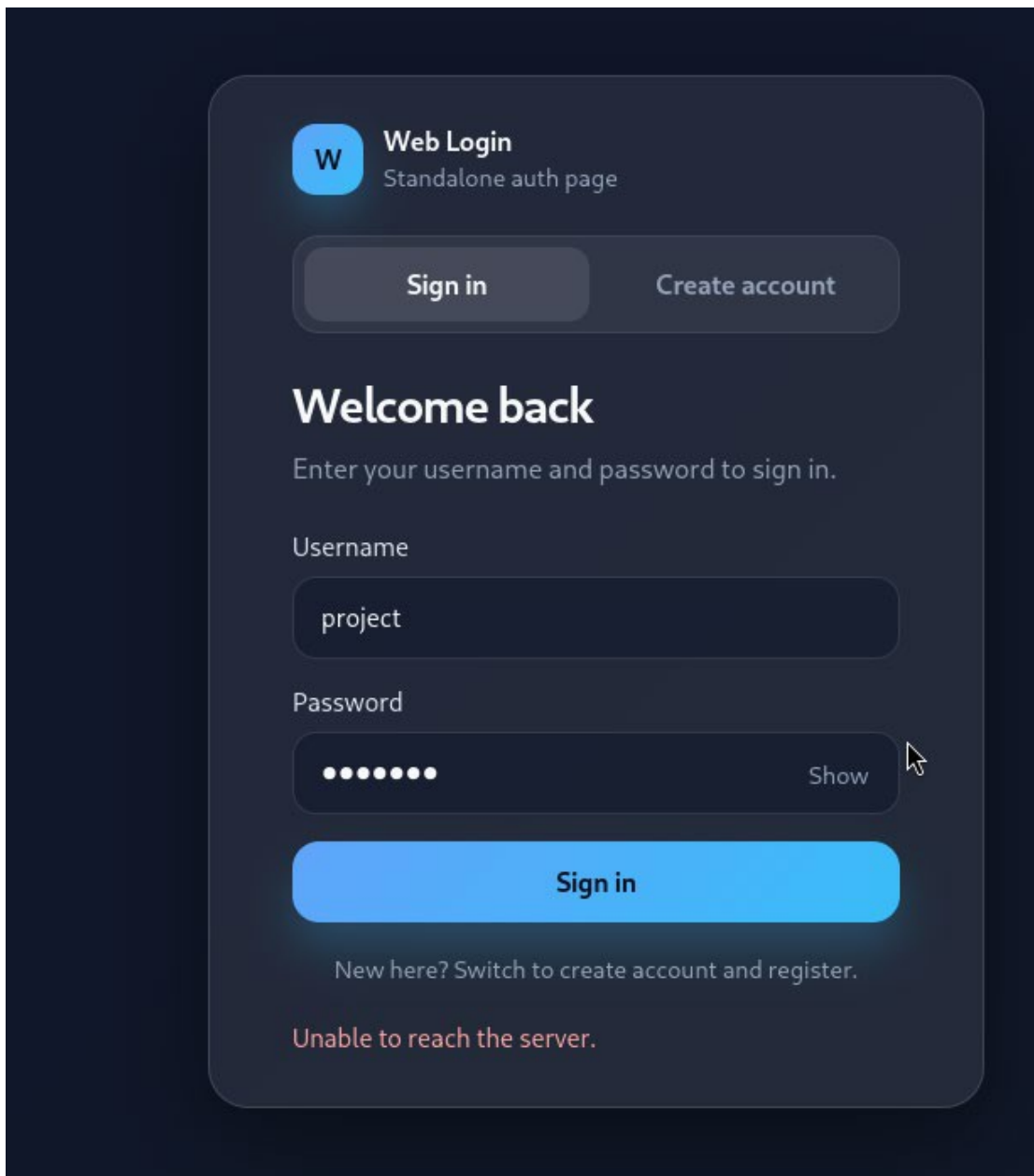


Figura 4. Clon en localhost después del envío del formulario, que muestra un error en línea de accesibilidad del servidor en lugar de una redirección limpia.

4. Evidencia recopilada

Como se muestra en la Figura 5, la sesión de terminal sirve como artefacto forense principal del estudio de caso. La salida muestra que la página de práctica alojada localmente fue clonada, servida correctamente al navegador y seguida por un evento de acceso registrado que identifica campos probables de nombre de usuario y contraseña del formulario enviado. Los detalles de direcciones locales y los valores enviados se redactaron antes de la publicación para que la evidencia siga siendo útil sin exponer detalles operativos innecesarios.

```
— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —
The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.1
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: http://127.0.0.1:5500/public/

[*] Cloning the website: http://127.0.0.1:5500/public/
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
127.0.0.1 - - [30/Mar/2026 21:40:04] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [30/Mar/2026 21:40:04] "GET //ws HTTP/1.1" 404 -
127.0.0.1 - - [30/Mar/2026 21:40:04] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: {"userna
POSSIBLE PASSWORD FIELD FOUND: {"userna
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C
```

Figura 5. Captura ampliada de la terminal que documenta el evento de envío registrado, con valores de dirección local y datos de credenciales enviados ocultos mediante barras negras opacas.

5. Por qué ocurrió la exposición

La captura funcionó porque la página presentada al usuario parecía una interfaz de inicio de sesión esperada y conservaba el patrón central de interacción de un formulario de acceso normal. La debilidad más importante demostrada aquí es el tiempo: los datos quedaron expuestos al enviarse, antes de que cualquier almacenamiento legítimo en backend, hash de contraseñas o control de seguridad de cuenta pudiera ser relevante.

Los factores humanos también importaron. Los usuarios suelen explicar la fricción de inicio de sesión como un error propio. Una página que permanece visible y muestra un mensaje de error puede incentivar otro intento en lugar de generar sospechas. La interfaz no necesita ser perfecta para tener éxito; solo necesita parecer plausible durante unos segundos, justo cuando el usuario está listo para escribir un nombre de usuario y una contraseña.

6. Impacto real para la persona

Para un usuario individual, la exposición de credenciales puede crear consecuencias que van mucho más allá de un solo formulario de inicio de sesión. Si la contraseña capturada se reutiliza, un solo envío puede desencadenar la toma de control del correo electrónico, abuso de restablecimiento de contraseñas, compras fraudulentas, bloqueo de cuentas, exposición de documentos personales o compromiso de almacenamiento en la nube y fotos familiares.

El impacto se amplifica en casa porque las personas son menos formales en dispositivos personales: inician sesión rápido, guardan contraseñas en navegadores, comparten dispositivos con familiares, siguen enlaces desde mensajes de texto y a menudo actúan mientras están distraídas. El daño no es solo técnico. Una víctima puede necesitar horas para recuperar cuentas, contactar a bancos o proveedores de servicios, explicar actividad sospechosa y reconstruir la confianza en los dispositivos y accesos que usa todos los días.

7. Mitigación, parcheo y prevención

La ruta de corrección para esta clase de exposición comienza en el punto de decisión donde se introducen las credenciales. El objetivo defensivo es hacer que la verificación del dominio sea más fuerte que la confianza visual. Los gestores de contraseñas que solo autocompletan en el dominio correcto pueden interrumpir de inmediato las páginas clonadas. Las passkeys, las llaves de seguridad de hardware y la autenticación multifactor resistente al phishing reducen la dependencia de contraseñas reutilizables y hacen que la reutilización de credenciales sea mucho más difícil.

Los controles preventivos también deben abordar cómo llegan los usuarios a las páginas de inicio de sesión. Las familias y las organizaciones pequeñas deben preferir marcadores u aplicaciones oficiales, mantener contraseñas únicas para cada servicio, activar alertas de inicio de sesión en cuentas de correo y financieras, y tratar un error de inicio de sesión inmediatamente después de introducir credenciales como una señal de advertencia, no simplemente como un error tipográfico. A nivel de dispositivo y red, navegadores y sistemas operativos actualizados, perfiles de navegador separados, filtrado DNS y menor reutilización de contraseñas reducen materialmente el riesgo de que una sola página convincente se convierta en un compromiso mayor de cuentas.

8. Consideración ética

Este estudio de caso se realizó en un entorno controlado estrictamente con fines educativos y analíticos. Tanto la interfaz de inicio de sesión de origen como la clonada se alojaron localmente, y todas las credenciales usadas durante las pruebas fueron autogeneradas. No participaron usuarios reales, sistemas externos, hosts públicos ni servicios de terceros. Las capturas de pantalla y salidas de terminal presentadas en este informe se tratan como artefactos de investigación de una simulación acotada, no como instrucciones para una aplicación en el mundo real.

Los hallazgos confirman que una interfaz de inicio de sesión clonada puede capturar credenciales en el punto de entrada, incluso cuando el comportamiento posterior al envío es imperfecto o produce errores visibles. La importancia de este caso es forense y defensiva: ilustra cómo flujos de inicio de sesión creíbles pueden exponer información sensible antes de que las protecciones confiables del backend sean relevantes. La lección defensiva es clara: verificar el destino, reducir la reutilización de contraseñas y tratar los errores de inicio de sesión inesperados como posibles pistas de detección, no como ruido de fondo inofensivo.